

## electron/security-scan-runner.cjs

Kind: added · Baseline: 9aadd5eb5604 · Target: NovaDiff · Generated: 2026-05-26T19:22:17.811Z

### Overview

A new module `electron/security-scan-runner.cjs` is added, exposing `runSecurityInsightScan`. It orchestrates multi-ecosystem vulnerability scans (OSV, npm, pip, cargo, govulncheck, bundle-audit) and aggregates results into a unified signal list.

### Key changes

- **Imports:** `fs`, `path`, `child_process.spawnSync`, `crypto` added at the top (lines 1-6).
- **Utility helpers:** `severityFromAdvisory`, `confidenceFromSeverity`, `hashId`, `relPathFromRoot` (lines 8-26).
- **Repository traversal:** `walkRepoForMarkers` (lines 33-77) now skips common build dirs and limits depth to 6.
- **Ecosystem detection:** `detectEcosystems` (lines 80-112) identifies Node, Python, Rust, Go, Ruby, JVM manifests.
- **Command runner:** `runCommand` (lines 114-124) normalizes Windows executables and enforces a 30 s timeout.
- **Parsers:** `parseNpmAudit`, `parsePipAudit`, `parseCargoAudit`, `parseOsvScanner` (lines 127-324) convert scanner JSON into `RiskSignal` objects.
- **Main flow:** `runSecurityInsightScan` (lines 332-607) validates `projectRoot`, runs each scanner conditionally, collects `signals` and `sources`, deduplicates by `id`, and returns `{scannedAt, signals, sources}`.
- **Export:** `module.exports = { runSecurityInsightScan }` (lines 609-611).

### Impact

- **Correctness:** Adds comprehensive coverage for multiple ecosystems; deduplication ensures no duplicate signals.
- **Maintainability:** Centralized parsing logic and helper utilities make future scanner additions straightforward.
- **Performance:** Synchronous `spawnSync` calls block the event loop; scanning may take up to ~45 s per tool, potentially impacting UI responsiveness.
- **Compatibility:** Requires the external scanners ( `osv-scanner`, `npm`, `pip-audit`, `cargo-audit`, `govulncheck`, `bundle-audit` ) to be on the host PATH; otherwise sources are marked as `skipped` or `warning`.
- **Observability:** Each scanner's status and duration are recorded in the `sources` array, aiding diagnostics.

### Risks & follow-ups

- **Missing scanners:** Verify that all required binaries are available in CI and developer environments; otherwise scans will be silently skipped.
- **Path resolution:** `walkRepoForMarkers` uses `path.relative` ; ensure it correctly handles Windows backslashes (already replaced).
- **Error handling:** `runCommand` only captures `error` and `stderr` ; consider propagating exit codes for non-zero statuses.
- **Performance:** Monitor cumulative scan time in large repos; consider async execution or parallelism if UI stalls.